

Narrativa explicativa de la Encuesta STRIDE

Érase una vez un sistema perfectamente seguro. Vivió cinco milisegundos, hasta que alguien decidió conectarlo a algo útil. Desde entonces, vivimos acompañados de seis jinetes discretos: suplantación, manipulación, negación, chismorreos no consentidos, saturación y coronación indebida de administradores. A falta de poesía normativa, Microsoft lo llamó STRIDE.

La encuesta que tiene entre manos no pretende descubrir nada revolucionario. Solo aspira a traducir a preguntas comprensibles lo que ya exigen NIS2, el ENS y el sentido común: que la identidad se verifique, que los datos no se manipulen alegremente, que los logs cuenten la historia, que la información privada no salga de paseo, que los servicios sigan respirando cuando arrecie el temporal y que los privilegios pesen lo justo.

Cada bloque de preguntas habla, en el fondo, de tres asuntos:

1. ¿Sabemos dónde estamos expuestos?
2. ¿Hacemos algo razonable al respecto?
3. ¿Lo medimos de forma que podamos mejorar, y no solo defender nuestra conciencia en auditoría?

El bloque de gobierno y threat modeling pregunta por el ritual que antecede al desastre o a su evitación: si alguien dibuja diagramas de flujo antes de desplegar sistemas críticos, si las amenazas se catalogan, si STRIDE es algo más que un acrónimo que suena a zapatillas de running.

Luego vienen las seis letras. En Spoofing, la encuesta indaga sobre MFA, PKI, identidades de máquinas, detección de intentos de suplantación. No se trata de buscar un 100 % de cobertura utópica, sino de saber si la organización ha asumido que, en el ecosistema actual, las credenciales son moneda de cambio y que todo lo que pueda ser suplantado, tarde o temprano, lo será.

Tampering habla de integridad. No tanto de la moral, que es asunto de recursos humanos, sino de los datos y las configuraciones. ¿Quién puede tocar qué, con qué trazabilidad?, ¿existen registros inmutables?, ¿las actualizaciones de firmware se parecen más a una cirugía programada o a un salto de fe? Aquí, las respuestas no solo reflejan controles, sino también cultura: la diferencia entre “cambiamos lo que haga falta en producción” y “documentemos este pequeño apocalipsis”.

Repudiation, la oveja teóricamente aburrida del rebaño, suele revelar las verdades incómodas: logs inexistentes, sospechosos a los que no se puede señalar porque el sistema “no guardaba tanto detalle”, acciones automatizadas sin firma ni registro. Las preguntas sobre logging, retención e inmutabilidad apuntan a una idea sencilla: sin historia fiable no hay atribución, sin atribución no hay lecciones aprendidas, y sin lecciones aprendidas hay repetición de exámenes.

Information Disclosure, por su parte, recuerda que todo sistema tiene vocación de chismoso. La encuesta explora inventarios de datos, clasificación, cifrado en reposo y en tránsito, evaluaciones de terceros, integraciones con nubes entusiastas y modelos de IA particularmente locuaces. No se trata solo de

cumplir con el RGPD, sino de entender que cada integración externa es un nuevo punto potencial de fuga y que cada modelo que aprende de nuestros datos puede también, si se le permite, improvisar sobre ellos.

En Denial of Service, la conversación se desplaza hacia la resiliencia. ¿Sabemos cuánto tiempo están realmente disponibles los servicios esenciales?, ¿hay protección frente a ataques de saturación?, ¿se han probado los planes de continuidad o son documentos de ficción especulativa?, ¿qué pasa si el propio SOC entra en apnea? La encuesta anima a distinguir entre “todo fue bien porque no pasó nada” y “todo fue bien porque, cuando pasó, aguantamos”.

Por último, Elevation of Privilege, el capítulo dedicado a esos pequeños golpes de Estado internos donde una cuenta normal se despierta un día con poderes divinos. Aquí se pregunta por PAM, por el principio de mínimo privilegio, por auditorías de permisos y por segregación de funciones. En muchas organizaciones, esta sección separa la seguridad como discurso de la seguridad como práctica: no hay Zero Trust digno de ese nombre sin una gestión seria de privilegios.

El bloque final, dedicado a métricas y ROI, es una invitación a abandonar la fe ciega (o cínica) en la seguridad como coste hundido y avanzar hacia una gestión mínimamente racional: decisiones informadas por datos, priorización basada en impacto, evaluación —aunque sea aproximada— del retorno de las medidas implantadas. La plantilla de Excel que acompaña a este kit pretende poner números donde solemos poner adjetivos.

En resumen, esta encuesta es una excusa cuidadosamente construida para hablar de cosas serias sin perder la capacidad de autocrítica. Si al completarla la organización descubre que le faltan logs, MFA, PAM o paciencia, no pasa nada: el desastre suele ser un proceso gradual, lo cual nos da tiempo —si lo aprovechamos— para frenarlo también gradualmente.